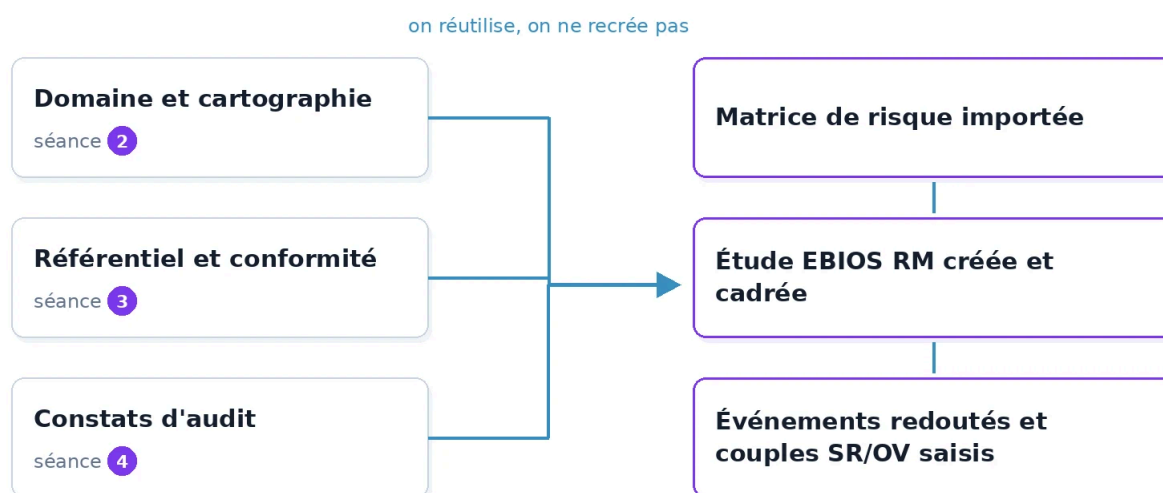


Saisie des Ateliers 1 et 2 dans CISO Assistant

✓ **Objectif : à la fin de l'heure, l'instance du groupe de travail porte l'étude**



Objectifs de la séance

Ce qui s'apprend dans ce TP :

- **Vérifier** que les objets créés aux séances précédentes dans CISO Assistant sont bien le socle de l'étude de risque, et les réutiliser sans les recréer
- **Importer** une matrice de risque depuis la bibliothèque de l'outil et expliquer pourquoi l'étude ne peut pas exister sans elle

- **Créer** l'étude EBIOS RM (expression des besoins et identification des objectifs de sécurité) du groupe MERIDIAN dans le module EBIOS RM de l'outil, rattachée au bon domaine, cadrée, reliée aux actifs et au socle
- **Saisir** les événements redoutés cotés en gravité, puis les couples source de risque / objectif visé évalués et sélectionnés, tels que le TD les a produits
- **Justifier** pourquoi les ateliers 3, 4 et 5 restent vides aujourd'hui, et ce que l'outil en dit

Prérequis

- Le TD de cet après-midi : le cadrage d'étude, les six événements redoutés cotés, la table de socle et les cinq couples SR/OV (source de risque / objectif visé) évalués, dont trois retenus. Ce TP saisit ce que le TD a produit : sans la copie du TD, il n'y a rien à saisir.
- L'instance CISO Assistant de la filiale instruite, avec les acquis des séances précédentes : le domaine de la filiale instruite et la cartographie saisie en séance 2, le référentiel importé en séance 3, l'audit de la séance 4.

Le principe du TP

Une étude de risque qui vit dans un document bureautique meurt à la première mise à jour. L'outil GRC (gouvernance, risque et conformité) du groupe est fait pour porter l'étude dans le temps : les cycles de révision de la méthode supposent qu'on retrouve, dans un an, les mêmes objets au même endroit, reliés aux mêmes actifs. Ce TP transpose donc les résultats des ateliers 1 et 2 dans le module EBIOS RM de CISO Assistant, et il applique une règle héritée de toute la formation : on réutilise, on ne recrée pas. Chaque objet saisi depuis la séance 2 va servir ; en recréer un doublon serait le début de la divergence entre l'outil et le réel.

Le module EBIOS RM de l'outil est construit sur les cinq ateliers du guide : une étude, et pour chaque atelier ses activités, nommées comme dans le guide. L'atelier 1 porte quatre activités, définir le cadre de l'étude, définir le périmètre métier et technique, identifier les événements redoutés, déterminer le socle de sécurité ; l'atelier 2 en porte trois, identifier les sources de risque et objectifs visés, évaluer les couples SR/OV, sélectionner les couples SR/OV. Ce sont, une à une, les quatre exercices du TD. La séance 6 remplira les ateliers 3 et 4 de la même étude, la séance 7 l'atelier 5, dont la première activité génère l'analyse de risque : rien ne sera recopié d'une séance à l'autre.

Un mot d'honnêteté sur l'interface : les libellés cités ici sont ceux de la version déployée sur la plateforme, vérifiés sur l'instance modèle. Si l'instance présente un écran légèrement différent, retrouver l'objet par son nom plutôt que par sa position dans le menu, et signaler l'écart dans le compte rendu : c'est exactement ce qu'un RSSI fait quand son outil évolue.

✓ Exercice 1 : l'inventaire de ce qui existe déjà (10 minutes)

Avant de saisir quoi que ce soit, prouver que le socle est là. Ouvrir l'instance et vérifier, en notant pour chacun le nom exact observé :

1. Le domaine de la filiale instruite créé en séance 2 (MERIDIAN-SANTE, MERIDIAN-LOGISTIQUE, MERIDIAN-EDUCATION ou MERIDIAN-TERRITOIRES), le second domaine qui porte l'autre bout de sa dépendance inter-filiale, et le périmètre associé à la filiale instruite.
2. Les actifs saisis en séance 2 : les valeurs métier et les biens supports de la filiale instruite, dont ceux de sa dépendance inter-filiale du 56 du dossier de filiale.
3. Le référentiel importé en séance 3 et l'évaluation de conformité créée avec lui, l'audit de la séance 4 avec ses états renseignés.
4. Le module EBIOS RM, menu Risque, entrée « EBIOS RM », page « Études EBIOS RM » : la liste est vide, c'est attendu.

À produire : une table de quatre lignes, objet attendu, présent ou absent, nom exact observé. Si un objet manque, ne pas le recréer en silence : le noter, le remonter, et poursuivre le TP avec ce qui existe. Un trou dans l'outil est une information de gouvernance, pas un obstacle personnel.

✓ Exercice 2 : importer la matrice de risque (10 minutes)

L'outil refuse par construction de créer une étude EBIOS RM sans matrice de risque : coter sans échelle ne veut rien dire, et l'outil est plus rigoureux que bien des organisations sur ce point. La bibliothèque de CISO Assistant propose plusieurs matrices prêtes à l'emploi ; celle qui concerne le module s'appelle « Matrice 4x4 EBIOS-RM », décrite comme basée sur le guide officiel de la méthode. Catalogue, Bibliothèques, chercher « EBIOS », importer.

L'importer depuis la bibliothèque, puis l'ouvrir et l'observer vraiment, car elle sera l'échelle de toute la suite du module :

1. L'axe de vraisemblance porte quatre niveaux, de V1 « Peu vraisemblable » à V4 « Certain ».
2. L'axe de conséquence porte quatre niveaux, de G1 « Mineur » à G4 « Critique ». À noter au passage, le mot choisi par l'outil : « Conséquence », là où le guide et le TD disent « gravité ». C'est le même concept, et ce doublon de vocabulaire est un excellent rappel : le vocabulaire d'ISO 27005 parle de conséquences là où EBIOS RM parle d'événements redoutés et de gravité.
3. Le croisement des deux axes produit trois niveaux de risque : Faible, Moyen, Élevé.

À produire : trois phrases. Laquelle des cases de la grille correspond au risque le plus élevé, quelle est la couleur de la diagonale, et surtout : les libellés de cette matrice sont-ils exactement ceux de l'échelle d'exemple du guide vue au TD ? Regarder de près les niveaux V4 et G3 avant de répondre.

✓ Exercice 3 : créer l'étude et poser le cadre, atelier 1, activités 1, 2 et 4 (15 minutes)

Menu Risque, entrée « EBIOS RM », puis le bouton d'ajout, l'icône en haut à droite de la liste. Nom, selon la convention du module : « Étude EBIOS RM MERIDIAN - [filiale instruite] et [dépendance du §6] - cycle 1 », où [filiale instruite] est le nom de la filiale dont le groupe tient le dossier et [dépendance du §6] l'intitulé court de sa principale dépendance inter-filiale, lue au §6 du dossier de filiale, par exemple « Santé et approvisionnement d'urgence » ou « Territoires et annuaire commun du pôle ». Domaine : celui de la filiale instruite, jamais le domaine racine. Matrice de risque : celle importée à l'exercice 2, c'est le geste qui lie l'étude à une échelle. Méthode de cotation : choisir « Manuelle », parce que la séance 7 saisira la vraisemblance de chaque scénario opérationnel à la main ; en « Expresse », l'outil la recalculerait depuis les modes opératoires et écraserait la saisie. Une fois l'étude créée, sa page affiche les cinq ateliers et leurs activités ; les trois de ce TP sont dans l'atelier 1.

1. **Cadrer**, activité 1 « Définir le cadre de l'étude » : renseigner la description de l'étude avec le cadrage du TD, l'objectif de l'étude en une phrase, les participants et leurs rôles, les durées des deux cycles, et la personne responsable d'accepter les risques résiduels. Un lecteur qui ouvre l'étude dans six mois doit y trouver le cadre sans avoir à chercher la copie de TD.
2. **Relier**, activité 2 « Définir le périmètre métier et technique » : sur la page de l'activité 2, le bouton « Sélectionner un actif » ouvre la liste des actifs existants, y cocher les valeurs métier et les biens supports de la filiale instruite saisis en séance 2, dépendance inter-filiale comprise. Ne pas toucher au bouton voisin « Ajouter un actif », qui en créerait un nouveau : ne rien créer, ne rien renommer, relier.
3. **Adosser**, activité 4 « Déterminer le socle de sécurité » : rattacher à l'étude l'audit de la séance 4, l'évaluation de conformité de la filiale. L'outil en tire le socle et ses écarts ; la table de socle du TD reste la référence écrite, et ses écarts conservés deviennent des données d'entrée de l'étude.

À produire : l'étude créée, visible dans la liste des études du domaine, avec son cadre en description, ses actifs reliés et son audit rattaché ; la carte « Synthèse » de la page de l'étude affiche les compteurs Actifs et Audits.

✓ Exercice 4 : saisir les six événements redoutés, atelier 1, activité 3 (20 minutes)

Depuis la page de l'étude, atelier 1, activité 3 « Identifier les événements redoutés », puis le bouton d'ajout de la liste, un par ligne du TD. Le formulaire porte les champs ID, Nom, Description, Gravité, Justification, Actifs, Qualifications et la case « Retenu ».

1. **Nommer** l'événement redouté avec la formulation du TD, celle qui nomme la valeur métier atteinte et le besoin de sécurité touché ; renseigner l'ID, ER1 à ER6, pour retrouver les lignes du TD.
2. **Relier** l'actif : la valeur métier concernée, saisie en séance 2. L'outil le rappelle sous le champ, un événement redouté se rattache aux valeurs métier, pas aux biens supports.
3. **Qualifier** le besoin de sécurité touché, parmi les qualifications de l'outil : Disponibilité, Intégrité, Confidentialité, et « Preuve » pour la traçabilité, l'outil n'employant pas ce mot.
4. **Coter** la gravité sur l'échelle de la matrice : Mineur, Significatif, Important, Critique. Correspondance avec l'échelle du TD, à noter sur la fiche : mineure = Mineur, significative = Significatif, grave = Important, critique = Critique.
5. **Justifier** la cote dans le champ Justification, avec la justification du TD, et cocher « Retenu ».

À produire : six événements redoutés dans la liste de l'activité 3, chacun avec son actif, sa qualification, sa gravité et sa justification ; le compteur « Événements redoutés » de la synthèse affiche 6.

✓ Exercice 5 : saisir les couples SR/OV, atelier 2 (25 minutes)

Depuis la page de l'étude, atelier 2, activité 1 « Identifier les sources de risque et objectifs visés », puis le bouton d'ajout de la liste, un par couple candidat du TD, cinq en tout. Le formulaire est découpé selon les trois activités de l'atelier, et c'est exactement l'ordre de l'exercice 4 du TD.

1. **Identifier**, activité 1 : la source de risque, dans les catégories de l'outil, État, Crime organisé, Terroriste, Activiste, Concurrent, Amateur, Vengeur, Pathologique, Autre ; puis l'objectif visé, formulé comme une finalité, dans les mots du TD. Le cybercriminel se saisit en « Crime organisé » ; le collaborateur ou prestataire malveillant en « Vengeur », la catégorie du guide pour l'initié.
2. **Évaluer**, activité 2 : la motivation (Très faible, Faible, Significatif, Fort), les ressources (Limité, Significatif, Important, Illimité) et le niveau d'activité (Très faible, Faible, Modérée, Important), puis la justification de l'activité par son élément observable dans le champ Justification. Correspondance avec les trois positions du TD : faible = Faible ou Limité, moyenne = Significatif ou Modérée, élevée = Fort, Important.

3. **Sélectionner**, activité 3 : cocher « Retenu » sur les trois couples sélectionnés au TD et laisser les deux autres décochés ; relier chaque couple, retenu ou non, aux événements redoutés qu'il vise, selon la table de correspondance du TD.
4. **Lire** la colonne Pertinence de la liste : l'outil la calcule seul en croisant motivation et ressources, sur quatre niveaux, de « Peu pertinent » à « Très pertinent ». Elle peut différer d'un cran de la pertinence du TD, parce que l'activité n'entre pas dans son calcul : noter l'écart sur la fiche, ne pas modifier la sélection pour lui plaire, c'est la justification écrite qui fait foi.

À produire : cinq couples dans la liste de l'atelier 2, trois retenus, chacun relié à au moins un événement redouté ; le compteur « Couples SR/OV » de la synthèse affiche 5.

Ce qui ne se fait PAS aujourd'hui, et pourquoi : les ateliers 3, 4 et 5 restent vides. La méthode l'exige encore : les scénarios stratégiques et l'écosystème sont l'objet de la séance 6, les scénarios opérationnels et leur vraisemblance aussi, et l'atelier 5 est celui de la séance 7, où la première activité, « Générer l'analyse de risques », créera le registre à partir de l'étude. Un atelier vide parce que la méthode n'y est pas encore est un état normal ; un atelier rempli d'objets improvisés est pire qu'un atelier vide, parce qu'il a l'air fini.



Corrigés et critères de validation – cliquer pour révéler